

BUỔI 05

Login & Phân quyền

Spring Security • JWT • Role-based Access Control



Authentication



Authorization



JWT Token





1

Xây dựng chức năng đăng nhập

Hiểu luồng POST /auth/login — kiểm tra mật khẩu, sinh JWT, trả token về client



2

Sinh & đọc JWT

Biết cấu trúc token, cách ký (sign), cách filter giải mã JWT ở mỗi request



3

Phân quyền theo role

Bảo vệ API với Spring Security: ADMIN, ACADEMIC_STAFF, CASHIER, PARENT có quyền khác nhau



AUTHENTICATION

Xác thực danh tính

- "Bạn là ai?"
- Kiểm tra username + password
- Nếu đúng → cấp JWT token
- Token là bằng chứng danh tính
- Dùng BCrypt để hash password



sau đó



AUTHORIZATION

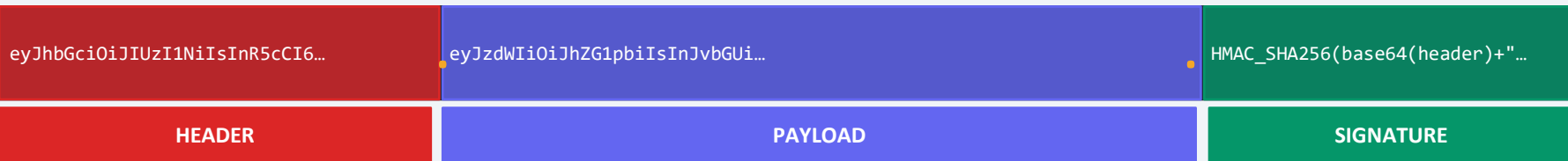
Phân quyền truy cập

- "Bạn được làm gì?"
- Đọc role từ JWT đã được verify
- ADMIN > ACADEMIC_STAFF > CASHIER
- Mỗi endpoint có @PreAuthorize
- 403 Forbidden nếu sai role



Cấu trúc JWT Token

Buổi 05 • Login & Phân quyền



HEADER

Algorithm + type
{ alg: HS256, typ: JWT }

⚠ Base64 encoded
(không phải mã hoá!)
Ai cũng đọc được

PAYLOAD

Claims: userId, role,
iat (issued), exp (expire)

sub	"admin_01"	– userId/username
role	"ADMIN"	– vai trò người dùng
iat	1700000000	– thời điểm cấp
exp	1700086400	– thời hạn hết

SIGNATURE

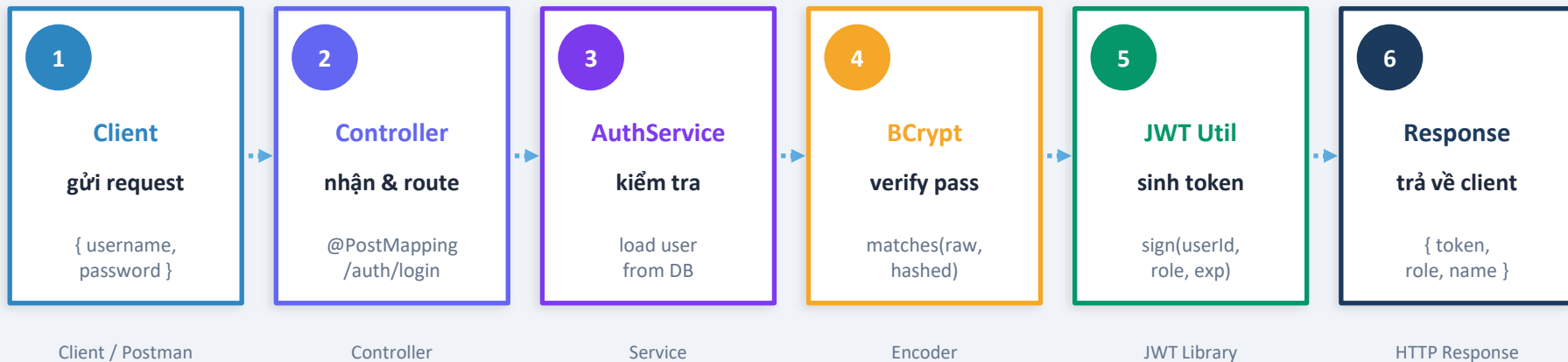
Ký bằng secret key
Bảo đảm không bị giả mạo

✅ Chỉ server có secret mới tạo/xác minh được
signature → không thể giả mạo token



Workflow A — Luồng đăng nhập (POST /auth/login)

Buổi 05 • Login & Phân quyền



Điểm cần nhớ: Không bao giờ lưu plain text password — luôn dùng BCrypt. JWT không chứa password, chỉ chứa userId + role. Secret key phải giữ bí mật tuyệt đối (để trong application.yml, không commit lên Git).



Workflow B — Bảo vệ API (Bearer Token)

Buổi 05 • Login & Phân quyền

Mỗi request gọi API bảo vệ đều đi qua Security Filter trước khi vào Controller:



200 OK – Cho phép

- Token hợp lệ, chưa hết hạn
- Role phù hợp với endpoint
- Controller được thực thi
- Dữ liệu trả về



401/403 – Từ chối

- 401: Không có / sai token
- 403: Token OK nhưng thiếu quyền
- Controller không chạy
- Body: { error, message }



Demo API – Chuỗi endpoint trên lớp

Buổi 05 • Login & Phân quyền

#	Method	Endpoint	Quyền cần	Mục đích demo
1	POST	/api/auth/login	PUBLIC	Đăng nhập — nhận JWT token
2	GET	/api/auth/me	ANY (có token)	Xem thông tin user hiện tại
3	GET	/api/students	ADMIN, ACADEMIC	Kiểm tra chặn theo role
4	GET	/api/students (CASHIER token)	CASHIER ✗	Demo lỗi 403 Forbidden
5	POST	/api/auth/login (sai pass)	PUBLIC	Demo lỗi 401 Unauthorized
6	GET	/api/auth/me (không có token)	—	Demo lỗi 401 – thiếu header



Demo theo thứ tự: login thành công → gọi /me → gọi API có quyền → gọi API thiếu quyền → token sai/hết hạn



Bài tập cuối buổi 5

01

Tạo 4 user theo role

Seed: ADMIN, ACADEMIC_STAFF, CASHIER, PARENT. Kiểm tra từng user gọi được / không gọi được API nào.

02

Phân quyền chi tiết

Thêm @PreAuthorize cho ít nhất 3 endpoint. CASHIER chỉ được /billing. PARENT chỉ được xem thông tin con.

03

Thử token hỏng / hết hạn

Gửi token sai → quan sát 401. Đặt expiry = 10s → đợi hết hạn → quan sát lỗi. Viết mô tả ngắn kết quả.

"Token xác định bạn là ai — Role quyết định bạn làm được gì."